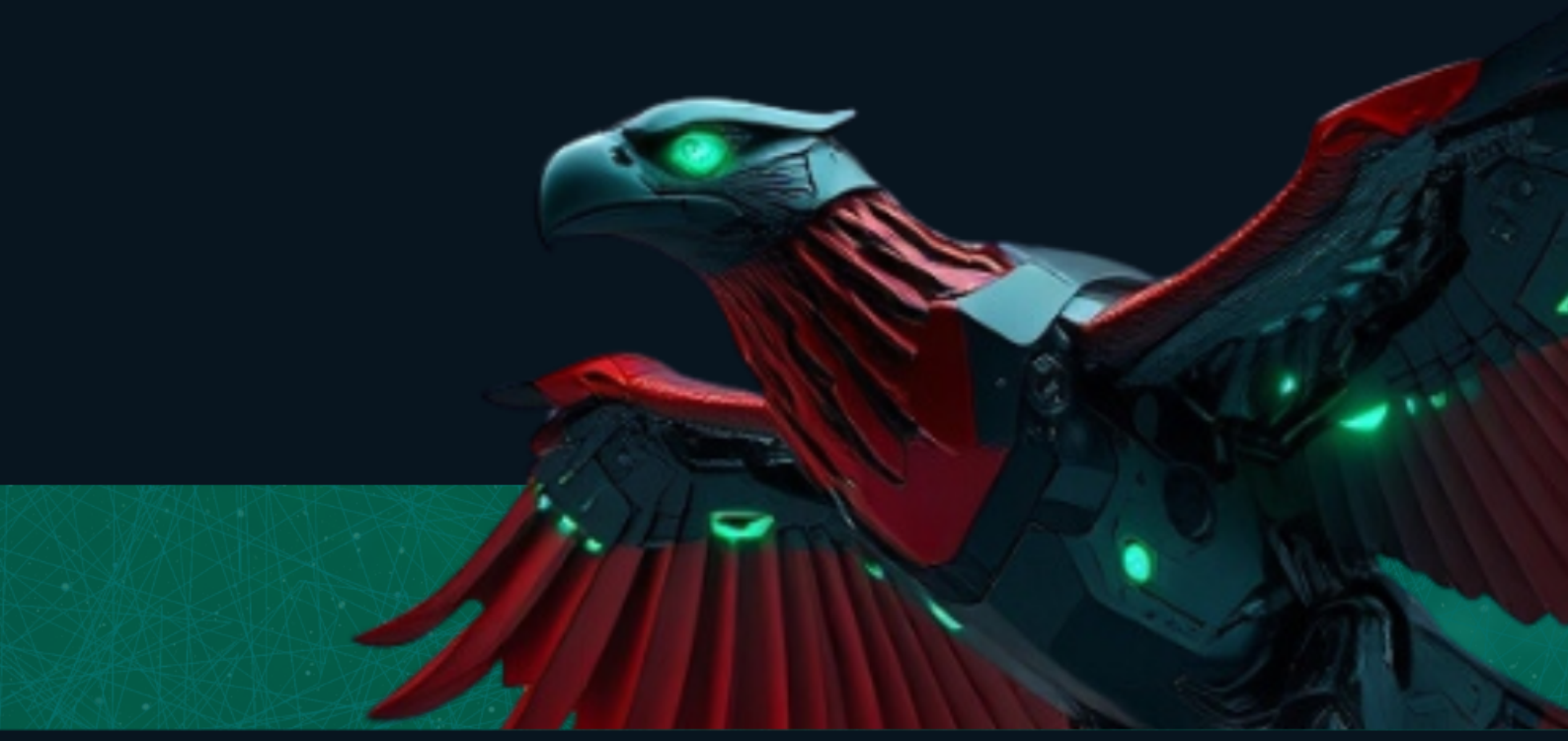
SOCBYTE
ALL BYTES SECURED

INTEL REPORT



Report Details

Title	CVE-2026-20079
Sub Title	A vulnerability in the web interface of Cisco Secure Firewall Management Center Software
Status	Closed
Type	Advisory
Severity	High
Source	Multiple Sources
Created At	Sep 14, 2026, 08:19 PM

CVE-2026-20079

A vulnerability in the web interface of Cisco Secure Firewall Management Center Software

Type: ADVISORY • Source: Multiple Sources • Created At: Sep 14, 2026, 08:19 PM

Analysis Summary

CVE-2026-20079 is a critical authentication bypass vulnerability affecting the web interface of Cisco Secure Firewall Management Center (FMC) software. Disclosed by Cisco in early March 2026, the flaw stems from an improper system process initialized at boot time that introduces an alternate path, bypassing authentication controls entirely. In September 2026, security telemetry confirmed active in-the-wild exploitation by sophisticated threat groups, including state-sponsored actors like Sandworm (tracked as UAT-11823) and access-broker clusters (UAT-12197), prompting CISA to officially add it to its Known Exploited Vulnerabilities catalog.

When exploited, an unauthenticated, remote attacker sends specifically crafted HTTP requests to an exposed FMC management interface. This allows the attacker to bypass access controls, execute arbitrary script files, and gain complete root-level privileges over the underlying operating system without requiring valid user credentials or administrator interaction. In real-world attacks, adversaries have leveraged this root access to drop malicious Java web shells, execute arbitrary code, and deploy custom malware implants such as Cyclops Blink along with SOCKS5 proxies and reverse-SSH tunnels.

The presence of this vulnerability poses a severe structural risk to enterprise infrastructure, as FMC serves as the central command node for network firewalls, intrusion prevention systems, and access policies. A full root compromise turns the appliance into an unchecked pivot point, enabling attackers to extract managed credentials, modify security rules, disable logging, and move laterally across internal subnets. There are no valid workarounds for this flaw, organizations must immediately apply vendor-issued software patches and strictly isolate FMC web interfaces behind trusted management VLANs or secure VPN gateways.

Affected Product

- Cisco Secure Firewall Management Center (FMC)
- Versions 7.0.x – 7.7.x and 10.0.x

Impact

- Authentication bypass vulnerability.
- Remote root access possible.
- Full system compromise risk.
- Attackers can execute arbitrary code.
- Enables credential theft and lateral movement.
- Critical threat to enterprise networks.

Vulnerabilities (CVEs)

CVE Number	Description	Published	CVSS Score
CVE-2026-20079	A flaw in the boot-time process handling of Cisco FMC's web interface permits unauthenticated attackers to bypass authentication entirely.	3/3/2026	10.0

Remediation

- Immediately apply Cisco-issued hotfixes for CVE-2026-20316 (contact your Cisco TAC or support provider if you do not have access to the appropriate patch or if guidance is required).
- Ensure that all security updates for CVE-2026-20079 and CVE-2026-20131 are applied.
- Monitor Cisco’s security portal and CISA KEV listings for updates or additional advisories.
- Restrict access to the FMC management interface (UI/API/CLI) using firewall or ACL rules—permit connections only from known, trusted IP addresses, preferably on isolated management networks or via secure VPN.
- Block all inbound traffic to FMC management ports (e.g., TCP 443, SSH) from untrusted or external sources.
- Periodically review all FMC credential stores (local, external), remove or disable default/static credentials, and enforce strong password policies.
- Harden FMC installations by disabling unused interfaces and enforcing least privilege access.
- Regularly update and audit FMC software and dependent libraries, following Cisco and industry best practices.

• Inform IT and network administrators of the urgency and technical details (recommend regular security briefings while the situation is ongoing).

• Assign resources to monitor for evolving vendor and CERT guidance.

• Restrict FMC management interface access

• Enforce network ACLs or firewall rules to allow only specific, trusted internal IPs/subnets.

• Place FMC behind a VPN or bastion host.

• Regularly audit FMC logs for suspicious or unauthorized access attempts.

• Disable unused management interfaces wherever possible.